

Secure C# MCP Agent Demo

Architecture Document

A reference implementation of a secure Model Context Protocol (MCP) server and rule-based client agent using .NET 8, JWT authentication, and scope-based authorization.

Version	1.0
Audience	Security Engineers & .NET Architects
Date	May 2026
Status	Demo / Educational
Repository	https://github.com/Priyendu/secure-csharp-mcp-agent-demo

1. Executive Summary

This document describes a reference architecture for a **secure Model Context Protocol (MCP)** server and rule-based client agent built with .NET 8.

The system demonstrates:

- HTTPS + JWT authentication with scope-based authorization (`mcp:tools`, `mcp:tools:release`)
- Audit logging of all auth and tool events
- Tool discovery endpoint (`/mcp/tools`)
- Negative security testing (401/403 handling)
- Four MCP security analysis tools for release workflows

Key Components:

- **SecureMcpServer** – ASP.NET Core 8 + JWT + SSE MCP endpoints
- **SecureMcpClientAgent** – Rule-based planner + sequential tool caller
- **DemoTokenService** + **SecurityAuditLogger** – Supporting security infrastructure

2. Context Diagram (C4 Level 1)

The system is designed as a self-contained demo with no external dependencies. Security engineers and release managers interact with the MCP server via JWT tokens.

External Context:

Security Engineer → JWT token request → SecureMcpServer (HTTPS) → SecureMcpClientAgent

3. Container View (C4 Level 2)

The architecture follows clean separation between the ASP.NET Core server, the console client, and shared security services.

SecureMcpServer (ASP.NET Core Web API)

- JWT Bearer Authentication
- Scope-based policies
- 4 security tools + tool discovery
- Audit logging

SecureMcpClientAgent (Console)

- Rule-based planner
- Token acquisition
- Sequential tool execution

4. Security & Authorization Model

All MCP endpoints require a valid JWT with the `mcp:tools` scope. Release approval operations additionally require the `mcp:tools:release` scope.

Endpoint	Required Scope	HTTP Method
<code>/auth/token</code>	None (dev only)	POST
<code>/mcp/sse</code>	<code>mcp:tools</code>	GET
<code>/mcp/messages</code>	<code>mcp:tools</code>	POST
<code>/mcp/tools</code>	<code>mcp:tools</code>	GET
<code>approve_release tool</code>	<code>mcp:tools:release</code>	Tool call

5. MCP Tools Exposed

- **get_component_security_profile** – Returns component criticality, exposure, and data sensitivity
- **check_known_vulnerabilities** – Returns CVE findings for a specific version
- **generate_security_assessment** – Deterministic risk scoring logic
- **create_release_security_summary** – Final release recommendation (Approved / BlockReleasePendingReview / etc.)

6. Production Hardening Recommendations

This demo is **NOT production-ready**. The following controls are required for real deployments:

- Replace demo JWT issuer with Entra ID / Okta / Ping Federate
- Use short-lived access tokens (15–60 minutes)
- Implement per-tool least-privilege scopes
- Add rate limiting and request validation
- Send structured logs to SIEM (Splunk, ELK, Sentinel)
- Review all MCP tools as privileged execution paths

Generated from ARCHITECTURE.md • Repository: secure-csharp-mcp-agent-demo